

ESPECIFICACIÓN FORMAL DE REQUERIMIENTOS: GHOST NOTES

Arquitectura de Sistemas y Protocolos de Gobernanza de Datos - v1.0

*Infraestructura escalable para la gestión de comunicaciones asíncronas anonimizadas con
protocolos de seguridad integrados.*

Aviso sobre este documento

Este documento es un artefacto de ingeniería de software de uso interno. Recoge requerimientos funcionales, no funcionales, de dominio y de arquitectura para el primer incremento de Ghost Notes. No constituye asesoramiento legal ni compromiso contractual con terceros.

Antes de cualquier lanzamiento público es obligatorio obtener asesoramiento legal sobre protección de datos (RGPD / LOPDGDD), responsabilidad por contenido generado por usuarios, edad mínima legal y condiciones de uso. Ninguna sección de este documento sustituye dicho asesoramiento.

Resumen ejecutivo

Ghost Notes se define como una infraestructura tecnológica orientada a la mediación de comunicaciones asíncronas bajo un modelo de anonimato controlado. A diferencia de las soluciones preexistentes en el mercado, este sistema prioriza la integridad de los datos, la gobernanza del receptor y un marco anti-abuso preventivo diseñado desde la capa de arquitectura. El objetivo estratégico es establecer un estándar de confiabilidad en la interacción digital, mitigando los riesgos inherentes a la comunicación no identificada.

Contexto de Mercado

El sector de la mensajería anónima atraviesa una fase de saturación caracterizada por la proliferación de plataformas que priorizan el crecimiento de la base de usuarios sobre la seguridad operativa. Competidores actuales han demostrado vulnerabilidades críticas en la moderación de contenido y la protección de menores, lo que ha derivado en una degradación de la confianza institucional. Ghost Notes surge como una respuesta técnica a esta saturación, ocupando el nicho de "Privacidad como Servicio" con rigor corporativo y cumplimiento normativo estricto.

Propuesta de valor diferencial

Anonimato responsable	El remitente no es visible para el receptor ni para otros usuarios, pero el sistema mantiene trazabilidad interna mínima para seguridad y cumplimiento legal. No se vende impunidad.
Sin anuncios invasivos	Modelo de monetización basado en donativos voluntarios y futuros perks estéticos opcionales. Las funciones de seguridad y privacidad nunca serán de pago.
Control real del receptor	Denuncia, bloqueo, pausa, regeneración de código y ocultación de notas están disponibles desde el primer incremento.
Anti-abuso desde el origen	Rate limiting, anti-bots, bloqueos y detección de patrones de enumeración son requisitos de primer orden, no afterthoughts.
Web-first	No se requiere app nativa para el MVP. El diseño es web-first con posibilidad de PWA en el tercer incremento.

Métricas de éxito del primer incremento

Flujo completo end-to-end	Un usuario puede registrarse, obtener su código, compartirlo y recibir una nota en menos de 3 minutos.
Privacidad verificada	Ningún endpoint de API expone senderUserId, email, IP ni metadata del remitente. Verificado por tests de API.
Protección básica funcional	Rate limiting activo bloquea abuso evidente sin afectar uso normal. Challenge anti-bot activable por riesgo.
Herramientas de receptor visibles	Denuncia, bloqueo y pausa son accesibles con un máximo de 2 acciones desde cualquier nota.
Percepción de calidad	Usuarios en beta perciben la experiencia como más limpia y segura que alternativas con anuncios.

1. Visión del producto

Ghost Notes permite que una persona reciba notas anónimas mediante un código o enlace propio, sin que el receptor conozca la identidad pública del remitente. La experiencia debe sentirse sencilla, íntima y segura. La promesa no es invisibilidad total, sino privacidad frente a otros usuarios con responsabilidad interna del sistema.

1.1 Declaración de visión

Para personas que quieren recibir opiniones sinceras, mensajes íntimos o feedback honesto de su entorno, Ghost Notes es una plataforma web de notas anónimas que combina privacidad social, control del receptor y anti-abuso desde el primer día — sin anuncios invasivos ni promesas irresponsables.

1.2 Posicionamiento competitivo

Característica	Tellonym	NGL	TwetLink	Ghost Notes
Sin anuncios invasivos	No	No	No	Sí ✓
Privacidad honesta (no absoluta)	Parcial	No	Parcial	Sí ✓
Anti-abuso nativo	Básico	Básico	Mínimo	Avanzado ✓
Control receptor (pausa/bloqueo)	Parcial	Sí	No	Completo ✓
Sin registro para enviar	Sí	Sí	Sí	No (MVP)
Web-first sin app	No	No	Parcial	Sí ✓
Moderación IA	Sí	Sí	No	Futura

2. Objetivos y alcance del primer incremento

2.1 Objetivos

El primer incremento valida el flujo principal de notas privadas anónimas por código, de extremo a extremo, con seguridad mínima razonable. No incluirá comunidad, feed público, conversaciones persistentes ni mecánicas avanzadas.

- Permitir registro, autenticación y gestión de sesión seguros.
- Generar un código o enlace de recepción único y difícil de adivinar por usuario.
- Permitir envío de nota privada anónima de usuario autenticado a código válido.
- Permitir al receptor leer sus notas sin conocer la identidad del remitente.
- Proveer herramientas básicas de protección: denuncia, bloqueo, pausa y regeneración de código.
- Aplicar controles anti-spam, anti-bots y rate limiting desde el primer despliegue.

2.2 Incluido en el primer incremento

- Registro con email y contraseña, verificación de email opcional en primer lanzamiento.
- Login, cierre de sesión y almacenamiento seguro de credenciales (hash BCrypt/Argon2).
- Código personal de recepción consultable y regenerable por el usuario.
- Envío de nota privada anónima por código con validaciones de contenido.
- Bandeja de notas recibidas paginada con estados: nueva, leída, ocultada, denunciada, eliminada.
- Denuncia de nota con motivo y comentario opcional.
- Bloqueo de remitente interno desde una nota sin revelar identidad.
- Pausa temporal o indefinida de recepción.
- Rate limiting por cuenta, IP y receptor.
- Protección anti-bots mediante señales de riesgo y challenge configurable.

2.3 Excluido del primer incremento

Todo lo que aparece a continuación está deliberadamente fuera del alcance del MVP. Incluir estas funcionalidades contaminaría el primer incremento y retrasaría la validación del core.

- Comunidad anónima tipo feed / Pinterest / Reddit.
- Conversaciones persistentes o chat anónimo entre remitente y receptor.
- Respuestas públicas a notas.
- Moderación automática con IA como dependencia principal.
- Sistema de donativos, suscripciones o perks integrado en la app.
- Aplicación móvil nativa (iOS / Android).
- Gamificación, ranking, karma o reputación pública.
- Notificaciones push nativas.
- Panel de moderación/administración completo.
- Integración con redes sociales externas.

3. Usuarios y actores del sistema

El sistema debe distinguir entre identidad interna y visibilidad externa. Que la interacción sea anónima para otros usuarios no significa que el sistema no tenga identidad ni trazabilidad. Esta distinción es fundamental para seguridad, protección frente a abuso y cumplimiento legal.

Usuario registrado	Persona con cuenta creada mediante email y contraseña. Puede ser receptor, remitente o ambos. Tiene identidad interna en el sistema.
Receptor	Usuario que posee un código de recepción activo y recibe notas. Controla su buzón y herramientas de protección.
Remitente	Usuario autenticado que envía una nota a un código válido. Su identidad no se muestra al receptor. Requiere cuenta verificada en lanzamiento público.
Administrador / Moderador	Rol interno para revisar denuncias, aplicar restricciones y gestionar abuso. No expuesto como panel completo en el MVP, pero el modelo de datos debe soportarlo.
Bot / Atacante automatizado	Actor no deseado que intenta enviar spam, enumerar códigos, crear multicuentas o acosar. No es un usuario legítimo. El sistema debe detectarlo y limitarlo.
Menores de edad	Subgrupo de usuarios con tratamiento especial. La política de edad mínima debe definirse antes del lanzamiento público conforme a RGPD/COPPA.

3.1 Casos de uso principales

Los siguientes casos de uso representan los flujos de mayor valor del primer incremento:

- CU-01: Registro y verificación de cuenta.
- CU-02: Autenticación y gestión de sesión.
- CU-03: Consultar y compartir código de recepción.
- CU-04: Regenerar o desactivar código de recepción.
- CU-05: Enviar nota privada anónima a un código.
- CU-06: Leer notas recibidas en bandeja.
- CU-07: Denunciar una nota recibida.
- CU-08: Bloquear al remitente de una nota.
- CU-09: Pausar recepción de notas.
- CU-10: Ocultar o eliminar nota de la bandeja.

4. Principios de anonimato y privacidad

Ghost Notes implementa una metodología de 'Privacy by Design' (Privacidad desde el Diseño), donde el anonimato social es una funcionalidad externa sustentada por una trazabilidad técnica interna robusta. La responsabilidad ética del sistema radica en la prevención de la impunidad operativa, garantizando que el diseño arquitectónico cumpla con el Principio de Proporcionalidad y las directrices del RGPD, separando estrictamente la identidad del usuario de sus interacciones públicas mediante capas de abstracción de datos.

4.1 Reglas de privacidad no negociables

- Ningún endpoint de lectura para el receptor debe exponer senderUserId, email, IP, user-agent ni metadata interna del remitente.
- Los DTOs públicos deben estar completamente separados de los modelos internos de persistencia.
- La denuncia no debe revelar la identidad del denunciado al receptor.
- El bloqueo funciona como 'bloquear a quien envió esta nota', sin mostrar quién es.
- La trazabilidad interna debe estar protegida mediante control de acceso y limitada a fines legítimos: seguridad, prevención de abuso y requerimientos legales.
- Los logs no deben contener datos personales innecesarios. Las IPs deben almacenarse hasheadas o con retención limitada.
- Ninguna respuesta de error debe revelar si un código existe, si un usuario existe o qué filtro fue activado.

4.2 Niveles de trazabilidad interna

Nivel 0 — Público	Datos visibles para cualquier usuario: contenido de nota (sin autor), existencia de un código activo, estados de nota (leída, nueva).
Nivel 1 — Receptor	Datos visibles solo para el dueño del buzón: lista de notas, fechas, estados. Nunca identidad del remitente.
Nivel 2 — Sistema / Seguridad	Datos internos: senderUserId, IP hasheada, user-agent hash, señales de riesgo. Solo accesibles por sistema de seguridad y moderación.
Nivel 3 — Legal	Datos conservados para cumplimiento legal: evidencia de denuncias graves, restricciones de cuentas. Acceso solo ante requerimiento legal o proceso interno documentado.

5. Requerimientos funcionales

Todos los requerimientos funcionales se presentan con identificador único, descripción, prioridad (Alta / Media / Baja) y módulo de dominio al que pertenecen.

5.1 Registro y autenticación

ID	Descripción	Prioridad	Módulo
RF-001	El sistema debe permitir registrar una cuenta con email y contraseña. El email debe ser único en el sistema.	Alta	identity
RF-002	El sistema debe validar: formato de email válido, longitud mínima de contraseña (≥ 8 caracteres), al menos un carácter especial o número.	Alta	identity
RF-003	El sistema debe almacenar exclusivamente el hash de la contraseña usando BCrypt (work factor ≥ 12) o Argon2id. Nunca texto plano ni cifrado reversible.	Alta	identity
RF-004	El sistema debe permitir iniciar sesión y emitir un token de sesión con expiración configurable (recomendado: access token ≤ 15 min + refresh token).	Alta	identity
RF-005	El sistema debe impedir acciones sensibles a usuarios no autenticados. Las rutas protegidas deben devolver 401 sin información adicional.	Alta	identity
RF-006	Para lanzamiento público, el sistema debe exigir email verificado antes de permitir enviar notas. El flujo de verificación debe ser resistente a enumeración de emails.	Alta	identity
RF-007	El sistema debe ofrecer un flujo seguro de restablecimiento de contraseña por email con tokens de un solo uso y expiración (≤ 1 hora).	Alta	identity
RF-008	El sistema debe implementar protección contra ataques de fuerza bruta en el endpoint de login: bloqueo temporal progresivo tras intentos fallidos configurables.	Alta	identity
RF-009	El sistema debe permitir cierre de sesión explícito con invalidación del token activo.	Media	identity
RF-010	El sistema debe soportar detección básica de sesiones concurrentes sospechosas (mismo usuario desde IPs geográficamente imposibles en ventana corta).	Baja	identity

5.2 Código de recepción

ID	Descripción	Prioridad	Módulo
RF-020	El sistema debe generar automáticamente un código de recepción único, criptográficamente aleatorio y difícil de adivinar (≥ 128 bits de entropía efectiva) para cada nuevo usuario.	Alta	receiving

ID	Descripción	Prioridad	Módulo
RF-021	El usuario debe poder consultar su código o enlace de recepción completo en cualquier momento desde su perfil.	Alta	receiving
RF-022	El usuario debe poder regenerar su código. El código anterior debe quedar invalidado de forma inmediata. Las notas previas no se pierden.	Alta	receiving
RF-023	El usuario debe poder pausar la recepción de notas durante un periodo determinado (1h, 24h, 7d) o indefinidamente.	Alta	receiving
RF-024	El sistema no debe permitir envío a códigos inexistentes, inactivos o pausados. La respuesta de error debe ser genérica para no revelar el estado.	Alta	receiving
RF-025	El enlace de recepción público debe ser opaco: no debe contener el userId ni información estructural del usuario.	Alta	receiving
RF-026	El sistema debe registrar cuándo se regeneró el código y por qué razón (manual, por abuso, por expiración futura si se implementa).	Media	receiving

5.3 Envío de notas privadas

ID	Descripción	Prioridad	Módulo
RF-030	Solo un usuario autenticado puede enviar una nota a un código válido. No se permite envío anónimo sin cuenta en el MVP.	Alta	privatenotes
RF-031	El contenido de la nota debe tener longitud mínima (≥ 2 caracteres) y máxima configurables (recomendado: ≤ 1000 caracteres en MVP).	Alta	privatenotes
RF-032	El sistema debe rechazar contenido vacío, demasiado largo, que supere filtros básicos de contenido prohibido o que sea identificado como spam por heurísticas simples.	Alta	privatenotes
RF-033	El sistema debe conservar internamente el recipientUserId y, cuando la estrategia de seguridad lo requiera, el senderUserId interno. Estos datos no son públicos.	Alta	privatenotes
RF-034	El envío debe pasar por la capa de políticas anti-abuso (rate limiting, bloqueos activos, restricciones de cuenta) antes de ser persistido.	Alta	privatenotes
RF-035	El sistema debe devolver mensajes de error genéricos al remitente que no permitan enumerar códigos, deducir si el receptor está activo ni evadir filtros.	Alta	privatenotes
RF-036	El sistema debe registrar un evento de dominio PrivateNoteSent para trazabilidad interna con timestamp, noteld y contexto de seguridad mínimo.	Media	privatenotes
RF-037	El sistema debe soportar configuración de campo 'tipo de nota' en futuras versiones (texto, pregunta, reto) sin romper el contrato actual de la API.	Baja	privatenotes

5.4 Bandeja de notas recibidas

ID	Descripción	Prioridad	Módulo
RF-040	El receptor debe poder listar sus notas recibidas ordenadas por fecha de creación descendente.	Alta	privatenotes
RF-041	La respuesta de la API no debe contener en ningún campo la identidad del remitente: ni senderUserId, ni email, ni apodo, ni ningún dato derivado.	Alta	privatenotes
RF-042	El receptor debe poder marcar notas como leídas, individualmente o en bloque.	Alta	privatenotes
RF-043	El receptor debe poder ocultar una nota de su bandeja (eliminación lógica). La nota no se elimina físicamente para preservar posibilidad de denuncia.	Alta	privatenotes
RF-044	El receptor debe poder eliminar definitivamente una nota de su bandeja. Una nota denunciada no debe poder eliminarse hasta que el proceso de denuncia esté cerrado.	Media	privatenotes
RF-045	El sistema debe soportar paginación cursor-based para evitar cargar grandes volúmenes y evitar inconsistencias con inserciones concurrentes.	Alta	privatenotes
RF-046	El sistema debe soportar filtrado básico por estado: todas, no leídas, ocultadas, denunciadas.	Media	privatenotes
RF-047	El sistema debe exponer un contador de notas no leídas sin necesidad de cargar toda la bandeja.	Media	privatenotes

5.5 Denuncias, bloqueo y protección del receptor

ID	Descripción	Prioridad	Módulo
RF-050	El receptor debe poder denunciar una nota recibida en cualquier momento mientras la tenga en su bandeja.	Alta	safety
RF-051	La denuncia debe incluir un motivo obligatorio seleccionable: acoso, insultos, amenaza, spam, contenido sexual, autolesión / suicidio, suplantación, otro.	Alta	safety
RF-052	La denuncia puede incluir un comentario opcional (máximo 500 caracteres) para contexto adicional.	Media	safety
RF-053	La nota denunciada debe ocultarse automáticamente de la bandeja activa del receptor. El receptor puede elegir volver a verla antes del cierre del proceso.	Alta	safety
RF-054	Las denuncias por autolesión, suicidio, amenaza o extorsión deben marcarse con severidad CRÍTICA y conservar evidencia completa para revisión y posible escalado.	Alta	safety

ID	Descripción	Prioridad	Módulo
RF-055	El receptor debe poder bloquear al remitente interno desde cualquier nota sin conocer su identidad. El bloqueo es silencioso para el remitente.	Alta	safety
RF-056	El sistema debe impedir nuevos envíos del remitente bloqueado hacia ese receptor. La respuesta al remitente debe ser indistinguible de un envío exitoso para evitar confirmación.	Alta	safety
RF-057	El receptor debe poder ver y gestionar su lista de bloqueos (listar y desbloquear) sin que se revele la identidad de los bloqueados.	Media	safety
RF-058	El receptor debe poder pausar recepción durante un periodo predefinido o indefinidamente. La pausa debe ser reversible con un solo gesto.	Alta	safety
RF-059	Las acciones de seguridad (denuncia, bloqueo, pausa) deben estar accesibles en un máximo de 2 interacciones desde cualquier nota.	Alta	safety

5.6 Anti-bots y anti-spam

ID	Descripción	Prioridad	Módulo
RF-060	El sistema debe aplicar límites de frecuencia por cuenta de remitente: máximo configurable de notas por minuto, hora y día.	Alta	safety
RF-061	El sistema debe aplicar límites por receptor para impedir acoso concentrado: máximo de notas recibidas desde cuentas distintas por unidad de tiempo.	Alta	safety
RF-062	El sistema debe aplicar límites por IP de forma proporcional, con consideraciones de privacidad: usar IP hasheada y ventana deslizante corta.	Alta	safety
RF-063	El sistema debe endurecer límites automáticamente para cuentas nuevas (< 24h) o con señales de riesgo elevado.	Alta	safety
RF-064	El sistema debe poder activar challenge anti-bot (Cloudflare Turnstile o equivalente) cuando el riesgo de la petición supere un umbral configurable.	Alta	safety
RF-065	El sistema debe detectar y penalizar intentos repetidos contra códigos inexistentes o patrones de enumeración de códigos.	Alta	safety
RF-066	El sistema debe registrar señales de seguridad (SafetySignal) sin incluir datos personales innecesarios. Las IPs se almacenan hasheadas.	Alta	safety
RF-067	El sistema debe soportar restricción manual de cuentas por parte de operadores internos: suspensión temporal, bloqueo de envío o cierre de cuenta.	Media	safety
RF-068	El sistema debe detectar heurísticamente envíos de contenido idéntico o muy similar desde la misma cuenta en ventana corta (spam repetitivo).	Media	safety

6. Requerimientos no funcionales

6.1 Seguridad

- RNF-001: Todas las entradas externas deben validarse y sanitizarse en el backend, independientemente de la validación en frontend.
- RNF-002: Los datos internos de trazabilidad (senderUserId, IPs, señales de riesgo) no deben exponerse por API ni UI.
- RNF-003: Las comunicaciones deben realizarse exclusivamente sobre HTTPS/TLS. No se permite HTTP en producción.
- RNF-004: Los tokens de sesión deben tener expiración, ser invalidables y almacenarse de forma segura. No deben incluirse en URLs.
- RNF-005: Los secretos de aplicación (claves JWT, credenciales de base de datos) deben gestionarse mediante variables de entorno o gestores de secretos. Nunca en el repositorio.
- RNF-006: El sistema debe aplicar headers de seguridad HTTP estándar: HSTS, X-Frame-Options, CSP, X-Content-Type-Options.
- RNF-007: Las contraseñas deben almacenarse con hash adaptativo (BCrypt o Argon2id) con factor de coste suficiente para resistir ataques offline modernos.

6.2 Privacidad y cumplimiento

- RNF-010: Los datos de trazabilidad interna no deben ser accesibles públicamente ni a través de endpoints no autorizados.
- RNF-011: Las IPs y user-agents deben almacenarse en forma hasheada con salt rotatable para minimizar la vinculación a personas físicas.
- RNF-012: El sistema debe soportar exportación de datos propios del usuario (derecho de acceso RGPD) en formato legible antes del lanzamiento público.
- RNF-013: El sistema debe soportar eliminación de cuenta con borrado o anonimización de datos personales (derecho al olvido RGPD).
- RNF-014: La política de retención de logs debe definirse y documentarse antes del lanzamiento: retención máxima recomendada de 90 días para señales técnicas.

6.3 Rendimiento

- RNF-020: El envío de una nota debe responder en < 500ms (p99) bajo carga moderada inicial (< 100 usuarios concurrentes).
- RNF-021: La carga de la bandeja de notas (primera página) debe responder en < 300ms (p99) bajo carga moderada.
- RNF-022: El sistema debe soportar paginación eficiente sobre colecciones grandes sin degradación lineal (cursor-based, no offset).
- RNF-023: Los índices de MongoDB deben estar definidos explícitamente para los campos de consulta críticos: recipientUserId, code, createdAt, status.

6.4 Escalabilidad y mantenibilidad

- RNF-030: El monolito modular debe mantener límites de módulo claros sin dependencias circulares verificadas por Spring Modulith.
- RNF-031: El diseño debe permitir extraer módulos como servicios independientes sin reescritura mayor si el volumen lo justifica.
- RNF-032: Los modelos de dominio no deben compartirse directamente entre módulos. La comunicación inter-módulo debe realizarse mediante interfaces públicas o eventos.
- RNF-033: El sistema debe soportar despliegue en entorno cloud estándar (Railway, Fly.io, AWS) con configuración externalizada por variables de entorno.

6.5 Observabilidad

- RNF-040: Los errores relevantes, eventos de abuso y bloqueos deben registrarse con nivel de severidad apropiado sin incluir secretos ni datos personales innecesarios.
- RNF-041: El sistema debe exponer métricas básicas de salud (health endpoint) compatibles con monitorización estándar.
- RNF-042: Los eventos de dominio críticos (PrivateNoteSent, SenderBlockedForRecipient, AccountRestricted) deben registrarse en un log de auditoría separado con retención extendida.
- RNF-043: El sistema debe distinguir errores operacionales (red, base de datos) de errores de dominio (código inactivo, límite superado) en los logs.

6.6 Usabilidad

- RNF-050: Las acciones de seguridad (denuncia, bloqueo, pausa) deben ser visibles y comprensibles para usuarios no técnicos sin lectura de documentación.
- RNF-051: Los mensajes de error mostrados al usuario deben ser informativos pero sin revelar detalles técnicos o internos del sistema.
- RNF-052: El flujo de registro y primer envío de nota debe poder completarse en menos de 3 minutos por un usuario nuevo sin asistencia.

7. Arquitectura y diseño de dominio

7.1 Estrategia arquitectónica: monolito modular

Ghost Notes se construirá como monolito modular (Spring Boot + Spring Modulith). Esta decisión permite mantener despliegue simple al inicio con límites de dominio claros desde el primer día, facilitando una eventual extracción a microservicios si el volumen lo justifica.

La estructura no debe basarse únicamente en capas técnicas (controller / service / repository). Debe basarse en capacidades de negocio verificables con límites explícitos.

7.2 Bounded contexts / módulos

identity	Registro, autenticación, credenciales, verificación de email y gestión de sesión. Core supporting subdomain. Ningún otro módulo debe importar directamente sus entidades internas.
receiving	Códigos de recepción, activación, regeneración, pausa y resolución de destinatarios. Supporting subdomain esencial. Expone interfaz de consulta de código válido sin exponer datos de usuario.
privatenotes	Creación, entrega, lectura y gestión de notas privadas anónimas. Core domain del primer incremento. Contiene la promesa principal del producto.
safety	Denuncias, bloqueo, rate limiting, anti-bots, restricciones y señales de abuso. No es un módulo accesorio: tiene reglas propias y debe consultarse antes de cualquier acción sensible.
notifications	Futuro: avisos internos, email y push ante eventos de dominio. No implementado en MVP.
community	Futuro bounded context para feed público anónimo, posts, replies y moderación. Completamente separado del core para no contaminar el MVP.

7.3 Tecnologías recomendadas

Backend	Java 21 + Spring Boot 3.x + Spring Modulith para verificación de límites de módulo.
Base de datos	MongoDB para documentos de notas, reportes y señales. Considerar PostgreSQL para identity y receiving si se prefiere consistencia fuerte.
Autenticación	JWT (access + refresh) con almacenamiento de refresh token en base de datos para invalidación.
Anti-bots	Cloudflare Turnstile (CAPTCHA invisible) como capa de challenge configurable.
Rate limiting	Bucket4j (Java) o Redis con sliding window. Redis recomendado para escalabilidad horizontal futura.
Frontend MVP	SvelteKit o Next.js. Web-first, sin dependencia de app nativa.

Infraestructura	Railway o Fly.io para MVP. Migración a AWS/GCP posible en incrementos posteriores.
Observabilidad	Micrometer + logs estructurados JSON. OpenTelemetry para trazas en versiones futuras.

8. Eventos de dominio

Los eventos de dominio son el contrato explícito entre módulos. Deben diseñarse desde el inicio aunque la implementación asíncrona completa llegue en incrementos posteriores.

Evento	Descripción	Módulo	Incremento
UserRegistered	Se creó una nueva cuenta con email y contraseña.	identity	1
EmailVerified	El usuario verificó su dirección de email.	identity	1
ReceivingCodeCreated	Se generó un código de recepción para un usuario.	receiving	1
ReceivingCodeRegenerated	El usuario regeneró su código (invalida el anterior).	receiving	1
ReceivingPaused	El usuario pausó la recepción de notas.	receiving	1
ReceivingResumed	El usuario reanudó la recepción de notas.	receiving	1
PrivateNoteSent	Una nota privada fue enviada y persistida correctamente.	privatenotes	1
PrivateNoteRead	Una nota fue marcada como leída por el receptor.	privatenotes	1
PrivateNoteReported	Una nota fue denunciada con motivo.	safety	1
SenderBlockedForRecipient	Un receptor bloqueó al remitente interno de una nota.	safety	1
AccountRestricted	Una cuenta fue restringida por abuso o riesgo detectado.	safety	1
NoteReportReviewed	Una denuncia fue revisada por moderación.	safety	2
AccountSuspended	Una cuenta fue suspendida por moderación.	safety	2

9. Modelo de datos conceptual

El modelo concreto evolucionará, pero el primer diseño debe proteger la separación entre datos internos y datos públicos. Se describe el modelo conceptual con campos mínimos necesarios para el primer incremento.

9.1 Account / User

Módulo: *identity* | Colección: *accounts*

id	ObjectId — identificador único del sistema.
email	String — email único, normalizado a minúsculas, indexado con unicidad.
passwordHash	String — hash BCrypt/Argon2id. Nunca texto plano.
emailVerified	Boolean — false hasta que el usuario completa el flujo de verificación.
status	Enum — ACTIVE SUSPENDED RESTRICTED DELETED.
createdAt	Date — timestamp de creación de la cuenta.
updatedAt	Date — timestamp de última modificación.
lastLoginAt	Date — timestamp del último login exitoso.

9.2 ReceivingCode

Módulo: *receiving* | Colección: *receiving_codes*

id	ObjectId — identificador único.
ownerUserId	ObjectId — referencia al usuario propietario del código.
codeSlug	String — token público opaco, generado con CSPRNG, indexado con unicidad.
active	Boolean — false si fue desactivado o reemplazado.
pausedUntil	Date? — null si no está pausado; fecha futura si hay pausa temporal; 'indefinite' como valor especial.
createdAt	Date — timestamp de creación.
regeneratedAt	Date? — timestamp de la última regeneración.
regenerationReason	String? — MANUAL ABUSE EXPIRATION.

9.3 PrivateNote

Módulo: *privatenotes* | Colección: *private_notes*

id	ObjectId — identificador único.
recipientUserId	ObjectId — referencia al receptor. Indexado.
senderUserId	ObjectId — referencia interna al remitente. NUNCA expuesto al receptor.
content	String — contenido de la nota. Indexado para búsqueda futura.
status	Enum — NEW READ HIDDEN REPORTED DELETED.
createdAt	Date — timestamp de creación. Indexado (orden de bandeja).
readAt	Date? — timestamp cuando el receptor la leyó.
hiddenAt	Date? — timestamp cuando el receptor la ocultó.
reportedAt	Date? — timestamp de la denuncia.
flagged	Boolean — true si un filtro de contenido la marcó como dudosa.

9.4 NoteReport

Módulo: *safety* | Colección: *note_reports*

id	ObjectId — identificador único.
noteld	ObjectId — referencia a la nota denunciada.
reportedByUserId	ObjectId — receptor que realizó la denuncia.
internalSenderId	ObjectId — remitente interno (no expuesto al reporter).
reason	Enum — HARASSMENT INSULTS THREAT SPAM SEXUAL SELF_HARM IMPERSONATION OTHER.
comment	String? — comentario opcional del receptor (máx. 500 chars).
severity	Enum — NORMAL HIGH CRITICAL. Calculado según reason.
status	Enum — PENDING REVIEWED RESOLVED DISMISSED.
createdAt	Date — timestamp de la denuncia.
reviewedAt	Date? — timestamp de revisión por moderación.

9.5 RecipientBlock

Módulo: *safety* | Colección: *recipient_blocks*

id	ObjectId — identificador único.
recipientUserId	ObjectId — usuario que realizó el bloqueo.
blockedSenderId	ObjectId — usuario bloqueado (interno, no visible para el receptor).
sourceNoteld	ObjectId? — nota que originó el bloqueo.

createdAt	Date — timestamp del bloqueo.
------------------	-------------------------------

9.6 SafetySignal

<i>Módulo: safety Colección: safety_signals</i>

id	ObjectId — identificador único.
userId	ObjectId? — null para señales sin cuenta asociada.
ipHash	String? — hash salteado de la IP origen. No permite reconstruir la IP original.
action	String — acción que generó la señal: SEND_NOTE LOGIN REGISTER ENUM_PROBE.
riskScore	Number — puntuación de riesgo (0-100) calculada por la política de safety.
metadata	Object — datos mínimos relevantes para análisis. Sin datos personales innecesarios.
createdAt	Date — timestamp. TTL index recomendado (90 días).

10. Estrategia de moderación y seguridad de contenido

El primer lanzamiento no debe depender de IA como juez absoluto. La estrategia es defensa por capas con validaciones deterministas como base, escalando a revisión humana para casos graves. La IA puede añadirse en el segundo o tercer incremento como evaluador opcional.

10.1 Capas de defensa

1. Validaciones deterministas: longitud, caracteres permitidos, contenido vacío.
2. Listas configurables de términos críticos (normalizadas para variantes unicode y l33tspeak básico).
3. Rate limiting por cuenta, IP y receptor.
4. Heurísticas de spam: contenido repetido, burst de envíos, patrones de enumeración.
5. Desafío anti-bot (Turnstile) cuando riesgo > umbral configurable.
6. Denuncias del receptor: primera línea de detección humana.
7. Bloqueo por remitente: acción inmediata del receptor.
8. Revisión manual de denuncias graves: amenaza, extorsión, autolesión, acoso coordinado.
9. IA como evaluador opcional (Incremento 2+): para contenido dudoso o borderline.

10.3 Protocolo de Escalado de Crisis

Para incidentes de severidad CRITICAL (amenazas a la integridad física, extorsión o contenido ilegal severo), se activa un protocolo de escalado de tres fases: 1. Aislamiento: Congelación inmediata de la cuenta emisora y preservación de logs en un entorno cifrado de solo lectura (cold storage). 2. Verificación Forense: Revisión por el Comité de Moderación bajo cadena de custodia digital. 3. Acción Institucional: Notificación proactiva a las autoridades competentes mediante los canales legales preestablecidos, garantizando la plena colaboración técnica sin comprometer la privacidad del resto de la base de usuarios.

10.2 Reglas de contenido en el MVP

- El sistema debe normalizar texto para detectar variantes simples de palabras prohibidas (unicode homogéneos, separadores de caracteres).
- El sistema no debe informar al remitente qué regla exacta activó un rechazo.
- Los mensajes claramente prohibidos pueden bloquearse antes de entrega (pre-delivery filter).
- Los mensajes dudosos pueden marcarse como flagged=true para revisión futura o tratamiento especial sin bloquearlos inicialmente.
- Casos graves (amenazas, extorsión, acoso coordinado, autolesión) deben conservar evidencia completa y elevar severidad de la denuncia a CRITICAL.

Recomendación: integrar Perspective API (Google) o un modelo de clasificación ligero en el Incremento 2 para contenido tóxico borderline. No debe ser el único juez ni bloquear sin revisión humana para casos graves.

11. Análisis de riesgos

El siguiente análisis de riesgos sigue el formato: riesgo, probabilidad (A/M/B), impacto (A/M/B) y mitigación recomendada.

Riesgo Estratégico	P.	I.	Justificación de Mitigación
Hostigamiento sistemático (Bullying)	A	A	Implementación de controles granulares del receptor y algoritmos de rate-limiting. La mitigación se justifica en la reducción del volumen de ataque, permitiendo que las herramientas de pausa y bloqueo silencioso neutralicen el incentivo psicológico del acosador.
Ataques coordinados (Brigading)	M	A	Detección de anomalías en patrones de tráfico y restricción de cuentas de baja antigüedad. Es esencial para evitar la saturación del servicio y proteger la salud mental del receptor mediante la detección temprana de clusters de cuentas maliciosas.

12. Estrategia de validación y verificación (V&V)

Verificación: comprobar que el sistema cumple los requisitos definidos. Validación: comprobar que el producto correcto se está construyendo para usuarios reales sin generar daños no previstos.

12.1 Niveles de testing

Tests unitarios	Reglas de dominio: límites de contenido, validación de código activo, cuenta verificada, bloqueo activo. Sin dependencias de infraestructura.
Tests de integración	Repositorios MongoDB, casos de uso principales end-to-end con base de datos en memoria o Testcontainers.
Tests de API	Verificación explícita de que ningún endpoint expone senderUserId, email, IP ni metadata interna. Pruebas de autorización y autenticación.
Tests de seguridad	OWASP Top 10 básico: SQL/NoSQL injection (aunque MongoDB), XSS, CSRF, rate limiting bypass, enumeración de recursos.
Tests arquitectónicos	Spring Modulith: verificación de que no existen dependencias no declaradas entre módulos. Ejecutados en CI.
Tests de privacidad	Verificar que los DTOs públicos no filtran datos internos. Revisar logs para asegurar ausencia de datos personales innecesarios.

12.2 Threat modeling por incremento

Antes de cerrar cada incremento se debe realizar un threat modeling ligero con la pregunta: ¿cómo abusaría un actor malicioso de esta feature específica? El resultado debe incluir al menos una mitigación adicional o una decisión documentada de aceptar el riesgo.

12.3 Beta cerrada

Antes del lanzamiento público se debe realizar una beta cerrada con usuarios reales de confianza para observar uso real, detectar riesgos no previstos y validar que las herramientas de protección del receptor son comprensibles sin documentación.

12.4 Criterios de aceptación por historia de usuario

Cada historia de usuario debe incluir criterios de aceptación explícitos en formato Given/When/Then. Los criterios relativos a privacidad deben incluir siempre un escenario negativo: verificar que la respuesta NO contiene los datos que no deben exponerse.

Ejemplo: DADO un receptor con notas recibidas, CUANDO llama a GET /api/notes, ENTONCES la respuesta no debe contener los campos senderUserId, senderEmail, senderIp ni ningún derivado de la identidad del remitente.

13. Estrategia incremental

Cada incremento debe entregar valor completo y verificable. No se inicia el siguiente incremento hasta que el anterior ha superado los criterios de aceptación y la beta correspondiente.

Inc.	Nombre	Contenido principal	Objetivo de validación
1	Buzón privado anónimo seguro	Registro, autenticación, código de recepción, envío de nota privada, bandeja, denuncia, bloqueo, pausa, rate limiting, anti-bots básico.	<i>Flujo e2e funciona. Privacidad verificada por tests de API. Anti-abuso básico operativo.</i>
2	Refuerzo anti-abuso y panel mínimo	Panel mínimo de reportes para operadores internos. Moderación IA opcional (Perspective API). Mejoras de rate limiting. Detección de brigading.	<i>Operadores pueden revisar denuncias CRITICAL. IA no bloquea sin revisión humana.</i>
3	Experiencia web/PWA y monetización	PWA instalable, personalización básica (temas), donativos opcionales (Ko-fi / Buy Me a Coffee). Mejoras UX del receptor.	<i>Retención de usuarios mejora. Donativos activos sin degradar experiencia gratuita.</i>
4	Respuestas limitadas o conversaciones consentidas	Respuestas anónimas opt-in activables por el receptor. Conversaciones con límite de rondas. Solo si se valida la necesidad real en Incremento 3.	<i>El receptor controla quién puede responderle. La funcionalidad no introduce nuevos vectores de acoso.</i>
5	Comunidad anónima	Feed público anónimo como bounded context separado. Posts, replies, moderación comunitaria, karma. Separado completamente del core de notas privadas.	<i>La comunidad no contamina la experiencia de notas privadas. Los límites de módulo se mantienen.</i>

14. Requisitos legales y de cumplimiento

Este documento no sustituye asesoramiento legal. Se recomienda consulta legal antes de cualquier lanzamiento público sobre protección de datos, responsabilidad por UGC, edad mínima y condiciones de uso.

14.1 Documentos legales obligatorios

- Política de privacidad: datos recogidos, finalidad, base legal (consentimiento / interés legítimo), retención, derechos del usuario (acceso, rectificación, supresión, portabilidad) y contacto DPO.
- Términos de uso: prohibición explícita de acoso, amenazas, spam, suplantación, contenido ilegal, contenido sexual no consentido y uso por menores de la edad mínima.
- Cookie policy / banner de consentimiento si se usan cookies de terceros o analytics.
- Política de edad mínima: definir edad mínima (recomendado 16 años como mínimo en la UE para consentimiento de tratamiento de datos) y proceso de reporte de cuentas de menores.

14.2 Retención y borrado de datos

Datos de cuenta	Conservar mientras la cuenta esté activa. Borrar o anonimizar en los 30 días siguientes a la solicitud de baja.
Contenido de notas	Definir política explícita. Recomendado: borrado físico tras 90 días de eliminación lógica por el usuario.
Señales técnicas (IP hash, user-agent)	TTL máximo recomendado: 90 días. Revisar con asesor legal según jurisdicción.
Evidencia de denuncias graves	Conservar durante el tiempo necesario para el proceso de moderación y posibles requerimientos legales. Documentar el criterio.
Logs de sistema	Máximo 90 días salvo requerimiento legal específico. Sin datos personales innecesarios en los logs.

14.3 Proceso de respuesta ante abuso grave

10. El sistema debe permitir a operadores internos acceder a evidencia de denuncias CRITICAL.
11. El proceso de revisión debe estar documentado antes del lanzamiento público.
12. Ante requerimiento legal válido (orden judicial, autoridades), debe existir un proceso interno documentado de respuesta.
13. Los casos de autolesión o suicidio deben tener un protocolo específico que incluya recursos de ayuda y posible escalado a autoridades.

15. Monetización y diferenciación

Ghost Notes no debe depender de anuncios invasivos. La diferenciación inicial es la propia experiencia: limpia, web-first, honesta sobre privacidad y con herramientas de protección reales.

15.1 Modelo de monetización por incremento

Incremento 1 — MVP	Sin monetización activa. El foco es validar el producto y construir confianza.
Incremento 2	Donativos opcionales mediante plataforma externa (Ko-fi, Buy Me a Coffee, Stripe). Sin perks ligados a seguridad.
Incremento 3+	Posibles perks estéticos para supporters: temas visuales, personalización del perfil, estadísticas avanzadas de bandeja, exportación de notas.

15.2 Principios de monetización no negociables

Las funciones de denuncia, bloqueo, pausa, privacidad y anti-abuso deben ser siempre gratuitas para todos los usuarios. La seguridad no es un perk de pago.

- Sin anuncios invasivos como principio de producto, no como promesa de marketing.
- Los perks de pago no deben incluir ventajas que perjudiquen la experiencia de usuarios gratuitos.
- El modelo de monetización debe ser compatible con la narrativa de privacidad honesta.

16. Criterios de éxito del primer lanzamiento

Estos criterios son los umbrales mínimos para considerar que el primer incremento está listo para lanzamiento público con beta cerrada.

Criterio	Método de verificación	Estado
Flujo registro → nota recibida completable en < 3 minutos por usuario nuevo	Test de usabilidad con usuarios reales	Pendiente
Ningún endpoint expone senderUserId ni metadata del remitente	Tests de API automatizados	Pendiente
Rate limiting bloquea abuso evidente sin afectar uso normal	Tests de carga y tests de política	Pendiente
Denuncia, bloqueo y pausa accesibles en ≤ 2 interacciones desde cualquier nota	Revisión UX y test de usabilidad	Pendiente
Todos los módulos pasan verificación de límites con Spring Modulith	Tests arquitectónicos en CI	Pendiente
Política de privacidad y términos de uso redactados y revisados legalmente	Revisión legal	Pendiente
Beta cerrada completada sin incidentes de privacidad graves	Beta con usuarios de confianza	Pendiente
Proceso de respuesta ante denuncia CRITICAL documentado y probado	Simulacro interno	Pendiente

17. Glosario

Anonimato social	Condición por la que el remitente no es identificable por el receptor ni por otros usuarios, aunque el sistema mantenga trazabilidad interna mínima.
Anti-bots / CAPTCHA	Mecanismos que dificultan la actuación automatizada no autorizada. En Ghost Notes se usa Cloudflare Turnstile como challenge configurable.
Bounded context	Límite explícito dentro del cual un modelo de dominio es válido y consistente. En Ghost Notes: identity, receiving, privatenotes, safety, etc.
Brigading	Acoso coordinado por múltiples cuentas distintas dirigido a un único receptor.
Bucket4j	Librería Java para rate limiting basada en algoritmo token bucket.
Challenge	Verificación activa de que el cliente es humano, activada bajo riesgo elevado.
Core domain	Área de mayor valor diferencial del negocio. En Ghost Notes: privatenotes.
DTO	Data Transfer Object — objeto de transferencia de datos que separa la representación pública de los modelos internos de persistencia.
Enumeración	Ataque que prueba sistemáticamente valores (códigos, emails) para deducir información del sistema.
Flagged	Estado interno de una nota marcada como potencialmente problemática por heurísticas o filtros, pendiente de revisión.
LOPDGDD	Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (España).
Monolito modular	Arquitectura donde todo el código se despliega como una sola unidad pero con límites de módulo explícitos y verificados.
PWA	Progressive Web App — aplicación web instalable con capacidades offline básicas.
Rate limiting	Control de frecuencia de peticiones para prevenir abuso. Se aplica por cuenta, IP y receptor.
RGPD / GDPR	Reglamento General de Protección de Datos (Unión Europea).
SafetySignal	Entidad interna que registra eventos de riesgo con puntuación y metadata mínima.
Spring Modulith	Extensión de Spring Boot para verificar y documentar límites entre módulos en tiempo de test.
Supporting subdomain	Área necesaria para el core domain pero sin diferenciación propia. En Ghost Notes: identity, receiving.
Threat modeling	Proceso de identificación sistemática de amenazas y definición de mitigaciones para una feature o sistema.
TTL index	Índice de MongoDB con tiempo de vida que elimina documentos automáticamente tras expirar.

UGC	User Generated Content — contenido generado por usuarios, sujeto a responsabilidad legal especial.
-----	--

18. Historial de cambios

Versión	Fecha	Autor	Cambios
0.1	2026-06-26	Equipo Ghost Notes	Documento inicial de requisitos.
1.0	2026-06-26	Revisión ampliada	Expansión completa: resumen ejecutivo, tabla de posicionamiento competitivo, RFs extendidos (RF-001 a RF-068), RNFs detallados, análisis de riesgos con tabla, modelo de datos extendido, estrategia de moderación por capas, criterios de aceptación, glosario y este historial.

— Fin del documento —